Cloud Security Posture Management on a Shoestring

Don Mallory

Hackfest - Québec, QC - Oct 31, 2026

Microsoft 365 & Azure Tools Matrix

Tool	Description	Key Capabilities	Requirements	Gap Addressed	Limitations / Notes	Output Format	Links
CIS Benchmarks	Security configuration baselines for Microsoft 365 and Azure.	Prescriptive hardening guidance, audit criteria, benchmark mappings, compliance validation.	Access to CIS Benchmarks (membership may be required for some content). Manual or automated assessment tooling needed.	Lack of standardized security baselines	Guidance only. Does not perform assessments itself. Requires another tool for validation.	N/A (guidance documents, PDF benchmarks)	https://www.cisecurity.org/benchmark/microsoft_365 https://www.cisecurity.org/benchmark/azure
ScubaGear	CISA Secure Cloud Business Applications assessment framework.	Assesses tenant settings against SCuBA guidance, generates HTML/CSV/JSON reports, policy validation using Open Policy Agent (OPA).	PowerShell, Microsoft Graph permissions, OPA/Rego policies.	M365 compliance visibility against federal guidance	Focused on SCuBA controls rather than comprehensive CIS coverage. Primarily M365-focused.	HTML, JSON, CSV	https://www.cisa.gov/resources-tools/services/secure-cloud-business-applications-scuba-project https://github.com/cisagov/
ScubaConnect	ScubaGear integration and collection framework.	Centralised collection of assessment results, automation support.	ScubaGear deployment and associated APIs.	Centralized reporting and multi-tenant assessment collection	Enhancement to ScubaGear ecosystem rather than standalone assessment platform.	JSON, API integration outputs	https://github.com/cisagov/ScubaConnect
Microsoft365DSC	Configuration-as-Code framework for Microsoft 365.	Tenant inventory, configuration export, drift detection, desired-state enforcement, CI/CD integration.	PowerShell, Microsoft Graph, various service-specific modules.	Configuration drift, undocumented settings	Complex setup in large tenants. Some services require legacy APIs due to Graph coverage gaps.	PowerShell exports, JSON, DSC configurations, reports	https://microsoft365dsc.com https://github.com/Microsoft365DSC/Microsoft365DSC
Prowler	Cloud security assessment platform supporting Azure and M365.	Security posture assessments, benchmark compliance checks, reporting, continuous monitoring.	Python-based CLI or SaaS platform; cloud permissions.	Limited cloud posture visibility	Coverage varies by cloud service. Advanced reporting features are stronger in commercial editions.	HTML, JSON, CSV, Excel, Compliance Reports	https://docs.prowler.com
Steampipe	SQL-based cloud governance and compliance engine.	Query cloud resources using SQL, compliance dashboards, custom controls, multi-cloud posture assessments.	Steampipe client plus Azure/M365 plugins.	Difficulty querying security posture across clouds	Requires SQL familiarity. Primarily query-oriented rather than remediation-focused.	Dashboards, SQL query results, CSV, JSON	https://hub.steampipe.io
Checkov	Infrastructure-as-Code security scanner.	Pre-deployment scanning of Terraform, ARM, Bicep, CloudFormation, Kubernetes manifests.	CI/CD integration or local execution.	Misconfigurations before deployment	Focuses on IaC rather than deployed environments.	CLI output, JSON, JUnit XML, SARIF, CycloneDX	https://www.checkov.io
Cloud Custodian	Compliance-as-Code platform.	Policy enforcement, automated remediation, event-driven governance, Azure resource management.	YAML policy definitions, cloud permissions.	Manual governance and enforcement gaps	Policy development can require significant effort.	JSON, logs, notifications, resource action reports	https://cloudcustodian.io
Open Policy Agent (OPA)	Policy-as-Code engine.	Rego policies, admission controls, CI/CD validation, API authorisation, compliance automation.	OPA engine and Rego policy development expertise.	Lack of unified policy enforcement	Not a security scanner by itself. Requires data sources and policies.	JSON, policy evaluation responses, API outputs	https://www.openpolicyagent.org
Purple Knight	Semperis identity security assessment tool.	Entra ID and Active Directory security assessments, identity risk identification, governance analysis.	Read access to identities and directories.	Identity governance weaknesses	Assessment-focused. Does not continuously enforce controls.	HTML, PDF, CSV assessment reports	https://www.semperis.com/purple-knight

Microsoft 365 & Azure Tools Matrix

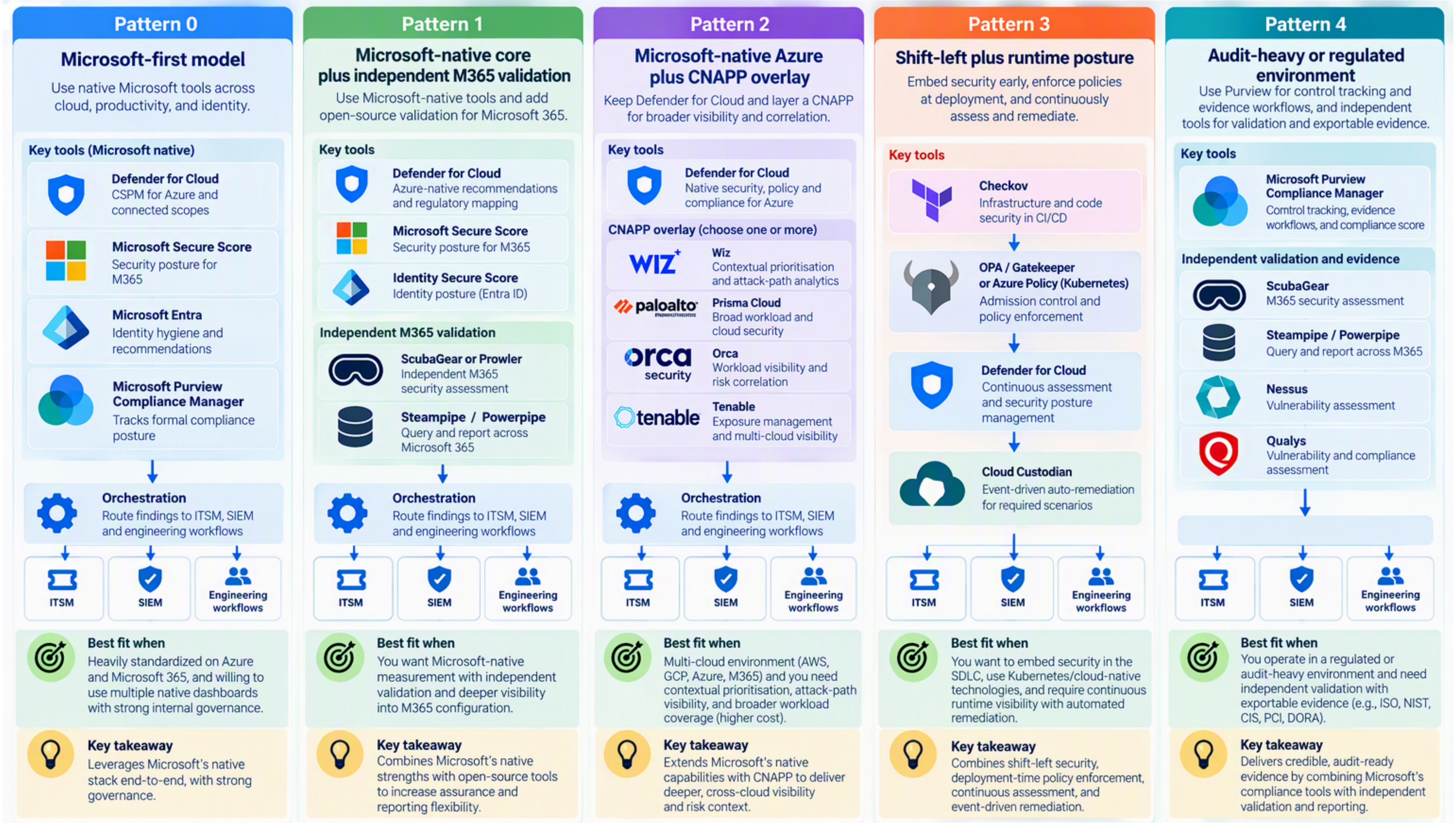
Tool	Description	Key Capabilities	Requirements	Gap Addressed	Limitations / Notes	Output Format	Links
Forest Druid	Semperis attack-path analysis platform.	Maps privilege escalation paths, attack-path discovery across AD and Entra ID.	Enterprise identity visibility and permissions.	Unknown privilege escalation and attack paths	Specialised for identity attack-path analysis rather than configuration compliance.	Interactive visualisation, reports, graphs	https://www.semperis.com/forest-druid
Azure Policy	Native Azure governance and compliance engine.	Policy enforcement, auditing, deny controls, remediation tasks, regulatory initiatives.	Azure subscriptions and appropriate RBAC roles.	Configuration drift and governance enforcement	Azure-focused only. Limited coverage of Microsoft 365 SaaS settings.	Compliance dashboards, JSON compliance results	https://learn.microsoft.com/azure/governance/policy/overview
ScoutSuite	Multi-cloud auditing platform.	Agentless posture assessments, HTML reporting, Azure security reviews, multi-cloud visibility.	Azure service principal or equivalent permissions.	Incomplete cloud security visibility	Primarily audit/reporting. Limited remediation capabilities.	Interactive HTML report, JSON	https://github.com/nccgroup/ScoutSuite
Monkey365	Microsoft cloud security review framework.	Deep assessments of Azure, M365, Entra ID, Secure Score data collection, HTML/CSV/JSON reports.	PowerShell, Graph permissions, extensive API permissions.	Azure/M365 security visibility gaps	Large data collections can be time consuming in enterprise tenants.	HTML, JSON, CSV, Power BI integration	https://silverhack.github.io/monkey365
AADInternals	Entra ID administration and security testing toolkit.	Tenant analysis, identity investigation, protocol testing, offensive/defensive security research.	PowerShell and administrative permissions.	Hidden identity attack paths and security exposures	Includes offensive security functions. Should be tightly controlled.	PowerShell results, JSON exports, console output	https://aadinternals.com/aadinternals
365Inspect	Microsoft 365 assessment framework from Soteria.	Automates M365 configuration reviews and security checks.	PowerShell access and tenant permissions.	M365 configuration visibility gaps	Smaller community and control library compared to Monkey365 or Microsoft365DSC.	Console output, reports, CSV	https://github.com/soteria-security/365Inspect
M365SAT	Microsoft 365 Security Assessment Tool.	Automated security control reviews and reporting.	PowerShell and tenant access.	Lack of automated security reviews	Limited ecosystem adoption relative to larger projects.	HTML, CSV, JSON	https://github.com/CompliantSec/M365SAT
M365Assessment	Microsoft 365 assessment scripts/toolset.	Configuration review, reporting, gap analysis.	M365 administrative permissions.	Basic tenant security visibility gaps	Community-supported project with varying coverage.	CSV, PowerShell reports	https://github.com/System-Admins/m365assessment
SkyArk	CyberArk cloud privilege analysis tool.	Detects shadow administrators, privilege escalation risks, excessive permissions.	Read access to cloud IAM configuration.	Hidden cloud administrators and privilege escalation	Identity and privilege focused rather than full cloud security posture.	HTML, CSV, JSON	https://github.com/cyberark/SkyArk
M365 UTCM PowerShell Tools	Tenant Configuration Management snapshot toolset.	Configuration snapshots, comparison, drift detection, change tracking.	Unified Tenant Configuration Management APIs and PowerShell.	Configuration drift and undocumented changes	Focused primarily on configuration comparison rather than compliance benchmarking.	JSON snapshots, PowerShell exports	https://github.com/therealtadda/M365UTCMPowershell

Microsoft 365 & Azure Tools Matrix

Tool	Description	Key Capabilities	Requirements	Gap Addressed	Limitations / Notes	Output Format	Links
Microsoft Graph PowerShell SDK	Microsoft Graph automation framework.	Custom auditing, reporting, compliance scripts, automation.	Graph API permissions and PowerShell.	Need for tailored auditing and reporting	Requires custom development. No built-in security benchmark framework.	JSON, CSV, PowerShell output, custom reports	https://learn.microsoft.com/powershell/microsoftgraph
Azure Resource Graph	Azure inventory and analytics service.	Large-scale resource discovery, KQL-based analysis, posture reporting.	Azure Reader permissions.	Incomplete Azure inventory visibility	Inventory and query platform rather than compliance engine.	KQL query output, JSON, CSV, dashboards	https://azure.microsoft.com/get-started/azure-portal/resource-graph
Azure-Audit	Community Azure audit framework.	Security, operational, and compliance assessments across Azure environments.	PowerShell/Azure permissions.	Gaps in Azure security reviews	Community maintained. Benchmark coverage depends on project updates.	HTML, CSV, JSON reports	https://github.com/adrian207/Audit-Azure
Azure Security Scanner	Azure subscription audit tool aligned to CIS.	70+ checks across multiple security categories, evidence collection, CIS-aligned reporting.	Azure subscription access.	Limited Azure CIS compliance visibility	Community-supported. Should be validated against current CIS versions.	HTML, PDF, CSV, evidence packages	https://phalanxcyber.ai/tools/azure-scanner.html https://github.com/Krishcalin/Azure-Security-Scanner
Azure CIS Scanner	Legacy CIS benchmark assessment tool.	CIS Azure Foundations benchmark checks.	Azure access.	Basic CIS Azure validation	Not actively maintained. Benchmark coverage is outdated.	CSV, console output	https://github.com/kbroughton/azure_cis_scanner
Azure Resource Graph	Azure inventory and analytics service.	Large-scale resource discovery, KQL-based analysis, posture reporting.	Azure Reader permissions.	Incomplete Azure inventory visibility	Inventory and query platform rather than compliance engine.	KQL query output, JSON, CSV, dashboards	https://azure.microsoft.com/get-started/azure-portal/resource-graph
Azure-Audit	Community Azure audit framework.	Security, operational, and compliance assessments across Azure environments.	PowerShell/Azure permissions.	Gaps in Azure security reviews	Community maintained. Benchmark coverage depends on project updates.	HTML, CSV, JSON reports	https://github.com/adrian207/Audit-Azure
Azure Security Scanner	Azure subscription audit tool aligned to CIS.	70+ checks across multiple security categories, evidence collection, CIS-aligned reporting.	Azure subscription access.	Limited Azure CIS compliance visibility	Community-supported. Should be validated against current CIS versions.	HTML, PDF, CSV, evidence packages	https://phalanxcyber.ai/tools/azure-scanner.html https://github.com/Krishcalin/Azure-Security-Scanner
Azure CIS Scanner	Legacy CIS benchmark assessment tool.	CIS Azure Foundations benchmark checks.	Azure access.	Basic CIS Azure validation	Not actively maintained. Benchmark coverage is outdated.	CSV, console output	https://github.com/kbroughton/azure_cis_scanner

But wait, there’s more




Pattern 0
Microsoft-first model
Use native Microsoft tools across cloud, productivity, and identity.
Key tools (Microsoft native)
Defender for Cloud
CSPM for Azure and connected scopes
Microsoft Secure Score
Security posture for M365
Microsoft Entra
Identity hygiene and recommendations
Microsoft Purview Compliance Manager
Tracks formal compliance posture
Orchestration
Route findings to ITSM, SIEM and engineering workflows
ITSM
SIEM
Engineering workflows
Best fit when
Heavily standardized on Azure and Microsoft 365, and willing to use multiple native dashboards with strong internal governance.
Key takeaway
Leverages Microsoft's native stack end-to-end, with strong governance.
Pattern 1
Microsoft-native core plus independent M365 validation
Use Microsoft-native tools and add open-source validation for Microsoft 365.
Key tools
Defender for Cloud
Azure-native recommendations and regulatory mapping
Microsoft Secure Score
Security posture for M365
Identity Secure Score
Identity posture (Entra ID)
Independent M365 validation
ScubaGear or Prowler
Independent M365 security assessment
Steampipe / Powerpipe
Query and report across Microsoft 365
Orchestration
Route findings to ITSM, SIEM and engineering workflows
ITSM
SIEM
Engineering workflows
Best fit when
You want Microsoft-native measurement with independent validation and deeper visibility into M365 configuration.
Key takeaway
Combines Microsoft's native strengths with open-source tools to increase assurance and reporting flexibility.
Pattern 2
Microsoft-native Azure plus CNAPP overlay
Keep Defender for Cloud and layer a CNAPP for broader visibility and correlation.
Key tools
Defender for Cloud
Native security, policy and compliance for Azure
CNAPP overlay (choose one or more)
Wiz
Contextual prioritisation and attack-path analytics
Prisma Cloud
Broad workload and cloud security
Orca
Workload visibility and risk correlation
Tenable
Exposure management and multi-cloud visibility
Orchestration
Route findings to ITSM, SIEM and engineering workflows
ITSM
SIEM
Engineering workflows
Best fit when
Multi-cloud environment (AWS, GCP, Azure, M365) and you need contextual prioritisation, attack-path visibility, and broader workload coverage (higher cost).
Key takeaway
Extends Microsoft's native capabilities with CNAPP to deliver deeper, cross-cloud visibility and risk context.
Pattern 3
Shift-left plus runtime posture
Embed security early, enforce policies at deployment, and continuously assess and remediate.
Key tools
Checkov
Infrastructure and code security in CI/CD
OPA / Gatekeeper or Azure Policy (Kubernetes)
Admission control and policy enforcement
Defender for Cloud
Continuous assessment and security posture management
Cloud Custodian
Event-driven auto-remediation for required scenarios
ITSM
SIEM
Engineering workflows
Best fit when
You want to embed security in the SDLC, use Kubernetes/cloud-native technologies, and require continuous runtime visibility with automated remediation.
Key takeaway
Combines shift-left security, deployment-time policy enforcement, continuous assessment, and event-driven remediation.
Pattern 4
Audit-heavy or regulated environment
Use Purview for control tracking and evidence workflows, and independent tools for validation and exportable evidence.
Key tools
Microsoft Purview Compliance Manager
Comtrol tracking, evidence workflows, and compliance score
Independent validation and evidence
ScubaGear
M365 security assessment
Steampipe / Powerpipe
Query and report across M365
Nessus
Vulnerability assessment
Qualys
Vulnerability and compliance assessment
ITSM
SIEM
Engineering workflows
Best fit when
You operate in a regulated or audit-heavy environment and need independent validation with exportable evidence (e.g., ISO, NIST, CIS, PCI, DORA).
Key takeaway
Delivers credible, audit-ready evidence by combining Microsoft's compliance tools with independent validation and reporting.

Pattern 0: Microsoft-first model

Use native Microsoft security and compliance tools across cloud, productivity, and identity, and integrate findings into operational workflows.

Built for a Microsoft-centric environment

Azure Microsoft 365

Defender for Cloud

Primary CSPM for Azure and connected scopes

- Cloud security posture management (CSPM)
- Findings and recommendations
- Multi-cloud and hybrid (connected scopes)

Microsoft Secure Score

Security posture for Microsoft 365

- Actionable security recommendations
- Tracks posture across M365 workloads
- Helps drive continuous improvement

Microsoft Entra

Identity hygiene and recommendations

- Identity security recommendations
- Risk detection and user hygiene
- Conditional access and identity governance

Microsoft Purview Compliance Manager

Tracks formal compliance posture

- Assesses regulatory compliance (e.g., ISO, NIST, CIS, etc.)
- Tracks control implementation
- Provides compliance score and improvement actions

Orchestration

Route findings and recommendations into operational workflows

- Automate and enrich findings
- Create and update tickets
- Trigger alerts and workflows
- Integrate with existing processes and tools

ITSM

Create and manage remediation tickets (e.g., ServiceNow, Jira)

SIEM

Send findings and alerts (e.g., Microsoft Sentinel, Splunk)

Engineering Workflows

Route to engineering and DevOps teams (e.g., Azure DevOps, GitHub)

Best fit when:

- Environment is heavily standardized on Azure and Microsoft 365
- Organization is willing to accept multiple native dashboards
- Strong internal governance to manage the Microsoft-native toolset

Key takeaway:

Leverages the full Microsoft security and compliance stack to deliver end-to-end visibility and action, with native integration into operational tools — ideal for Microsoft-centric organizations.

Pattern 1: Microsoft-native core plus independent M365 validation

Use Microsoft-native security tools for primary measurement and recommendations, and add open-source validation tools to independently assess Microsoft 365 and produce additional reporting.

Goal
Microsoft-native insights with independent validation for greater assurance.

Microsoft-native core

Defender for Cloud
Azure-native recommendations and regulatory mapping

- Cloud security posture management (CSPM)
- Azure security recommendations
- Regulatory compliance mapping (e.g., CIS, NIST, ISO)

Microsoft Secure Score
Security posture for Microsoft 365

- Actionable security recommendations
- Tracks posture across M365 workloads
- Benchmarks and improvement guidance

Identity Secure Score
Identity security posture (Entra ID)

- Identity security recommendations
- Risk detection and user hygiene
- Conditional access and identity governance

Independent M365 validation

ScubaGear or Prowler
Independent Microsoft 365 security assessment

- Open-source, community-driven
- Validates M365 configuration against security baselines
- Generates detailed reports and remediation guidance

Steampipe / Powerpipe
Query and report across Microsoft 365

- Open-source, extensible
- SQL-based queries against Microsoft 365 APIs
- Customizable dashboards and compliance reporting

Consolidate and operationalize
Combine native and independent findings for a unified view and action.

- Normalize and de-duplicate findings
- Map to compliance frameworks
- Route to ITSM, SIEM, and engineering workflows
- Track remediation and measure progress

ITSM
Create and manage remediation tickets (e.g., ServiceNow, Jira)

SIEM
Send findings and alerts (e.g., Microsoft Sentinel, Splunk)

Engineering Workflows
Route to cloud and M365 teams (e.g., Azure DevOps, GitHub)

Best fit when:

- You want Microsoft-native posture measurement with independent validation
- You need deeper visibility into Microsoft 365 configuration and reporting
- You value open-source tools to complement Microsoft's native insights

Key takeaway:

Combines the strengths of Microsoft-native tools with independent M365 validation (ScubaGear/Prowler and Steampipe/Powerpipe) to increase assurance, reporting flexibility, and trust in your security posture.

Pattern 2: Microsoft-native Azure plus CNAPP overlay

Keep Defender for Cloud for native policy alignment, and layer a CNAPP (Wiz, Prisma Cloud, Orca, or Tenable) for contextual prioritisation, attack-path analytics, workload visibility, and cross-domain correlation.

Best for multi-cloud
Valid for AWS, GCP, Azure, and M365 environments. Higher cost, broader visibility and correlation.

Microsoft-native (Azure)

Defender for Cloud
Native security, policy and compliance for Azure

- Cloud security posture management (CSPM)
- Native policy alignment and regulatory mapping
- Recommendations and security posture for Azure

CNAPP overlay (multi-cloud)

WIZ | paloalto NETWORKS Prisma Cloud | orca security | tenable

Layer a CNAPP for broader visibility, contextual prioritisation and correlation

- Contextual risk prioritisation (critical assets, exploitability, business context)
- Attack-path analytics (identity to cloud to data)
- Workload and container visibility (VMs, containers, serverless, Kubernetes)
- Cross-domain correlation (cloud, identity, data, workloads)
- Multi-cloud coverage: AWS, GCP, Azure and Microsoft 365
- Unified risk insights and reporting

Multi-cloud environment

- Microsoft Azure
- Amazon Web Services
- Google Cloud
- Microsoft 365

CNAPP provides unified visibility, correlation and risk context across all environments.

Consolidate and operationalize

Combine Microsoft-native and CNAPP findings for a unified view and action.

- Deduplicate and correlate findings
- Contextualise and prioritise risk
- Map to compliance frameworks
- Route to ITSM, SIEM, and engineering workflows
- Track remediation and measure progress

ITSM
Create and manage remediation tickets (e.g., ServiceNow, Jira)

SIEM
Send findings and alerts (e.g., Microsoft Sentinel, Splunk)

Engineering Workflows
Route to cloud and platform teams (e.g., Azure DevOps, GitHub, Terraform)

Best fit when:

- You operate in a multi-cloud environment (AWS, GCP, Azure, M365)
- You need contextual prioritisation, attack-path visibility, and cross-domain correlation
- You have budget for a CNAPP and want broader workload and identity-to-cloud insight

Key takeaway:

Extends Microsoft-native strengths with CNAPP capabilities to deliver deeper, cross-cloud visibility and risk context. Higher cost, but ideal for complex, multi-cloud environments.

Pattern 3: Shift-left plus runtime posture

Embed security early in the development lifecycle, enforce policies at deployment, continuously assess runtime posture, and automate remediation for a more secure and resilient environment.

Applies across

Azure · Kubernetes · Cloud workloads (and multi-cloud)

1. Shift-left (CI/CD)

Checkov

Infrastructure and code security in CI/CD

- Scan Terraform, Bicep, CloudFormation, Kubernetes manifests, and more
- Enforce policy-as-code and security best practices early
- Fail builds on critical issues
- Shift security left in the SDLC

Prevent misconfigurations before deployment

2. Admission control (Kubernetes)

OPA (Open Policy Agent) or **Azure Policy (for Kubernetes)**

Enforce security policies at deployment time

- Validate Kubernetes workloads (e.g., via OPA/Gatekeeper)
- Or use Azure Policy for Kubernetes (AKS)
- Block non-compliant deployments
- Enforce organisational and regulatory policies

Stop risky workloads from running

3. Runtime posture (Cloud)

Defender for Cloud

Continuous assessment and security posture management

- Assess cloud resources, containers, Kubernetes and workloads
- Identify vulnerabilities, misconfigurations and risky configurations
- Provide security recommendations and regulatory compliance mapping
- Monitor drift and changes over time

Gain continuous visibility and prioritised risk insights

4. Event-driven remediation

Cloud Custodian

Automated, event-driven remediation

- Define policies for automated actions
- Respond to cloud events (e.g., resource changes, security findings)
- Remediate or notify (e.g., stop instances, remove public access, tag resources)
- Support multi-cloud (AWS, Azure, GCP) with extensible policies

Automatically reduce risk and enforce compliance

Consolidate and operationalize

Route findings, policy violations, and remediation activity into your operational workflows.

- Ingest findings and events
- Create and update tickets
- Trigger alerts and automation
- Track remediation and measure improvement

ITSM

Create and manage remediation tickets (e.g., ServiceNow, Jira)

SIEM

Send findings and events (e.g., Microsoft Sentinel, Splunk)

Engineering Workflows

Integrate with DevOps and platform teams (e.g., Azure DevOps, GitHub, GitLab)

Best fit when:

- You want to embed security early in the SDLC
- You use Kubernetes and/or cloud-native technologies
- You need continuous runtime visibility and automated remediation

Key takeaway:

Combines shift-left security, deployment-time policy enforcement, continuous cloud posture assessment, and event-driven remediation to reduce risk and keep environments secure by design and by operation.

Pattern 4: Audit-heavy or regulated environment

Use Purview Compliance Manager for control tracking and evidence workflows, and use ScubaGear, Steampipe/Powerpipe, Nessus, and Qualys for independent validation and exportable evidence.

Goal
Demonstrate and maintain compliance with regulatory requirements through independent validation and audit-ready evidence.

1. Control tracking and evidence workflows

Microsoft Purview Compliance Manager

Track controls, assess compliance, and manage evidence

- Use regulatory templates (e.g., ISO, NIST, CIS, PCI, DORA)
- Track control implementation and progress
- Manage evidence collection, tasks, and attestations
- Generate compliance score and reports

Centralize compliance management and evidence workflows

2. Independent validation and assessment

ScubaGear

Open-source Microsoft 365 security assessment

- Validate M365 configuration against security baselines
- Generate detailed reports
- Export evidence for audits

Steampipe / Powerpipe

Query and report across Microsoft 365

- Run SQL-based queries against Microsoft 365 APIs
- Generate custom reports
- Export data for evidence packs

Nessus

Vulnerability assessment

- Identify vulnerabilities in cloud and on-prem assets
- Validate configuration and patching status
- Export scan results and evidence

Qualys

Cloud platform for vulnerability and compliance

- Assess cloud, SaaS, and on-prem infrastructure
- Validate compliance and security posture
- Export reports for audit evidence

3. Audit-ready evidence and reporting

- Consolidate evidence from Purview, ScubaGear, Steampipe/Powerpipe, Nessus, and Qualys
- Map evidence to regulatory frameworks (e.g., ISO, NIST, CIS, PCI, DORA)
- Generate audit-ready reports and exportable evidence packs
- Support internal and external audit processes
- Track ongoing compliance and remediation activities

Produce defensible, exportable evidence for auditors and regulators

Operationalize and integrate

Ingest findings and evidence into your operational workflows for continuous compliance.

- Automate evidence collection and updates
- Route findings to ITSM, SIEM, and risk management tools
- Track remediation and control effectiveness
- Maintain audit readiness year-round

ITSM

Create and manage remediation tickets (e.g., ServiceNow, Jira)

SIEM

Send findings and alerts (e.g., Microsoft Sentinel, Splunk)

Risk, GRC and Audit

Share evidence with GRC and audit teams (e.g., Archer, ServiceNow GRC, AuditBoard)

Best fit when:

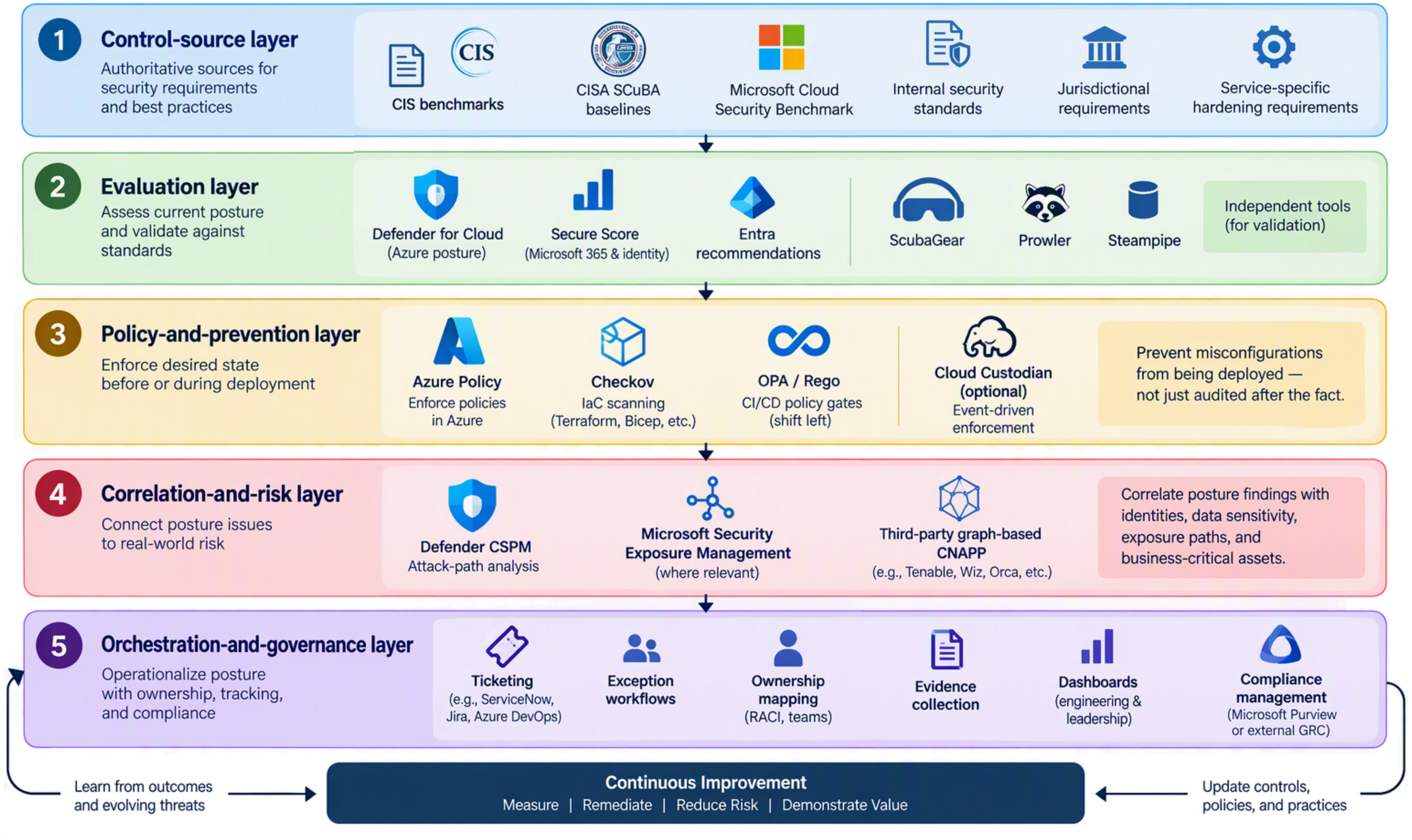
- You operate in a regulated or audit-heavy environment
- You need independent validation and exportable evidence
- You must demonstrate ongoing compliance with recognized frameworks

Key takeaway:

Combines Microsoft's compliance management with independent validation tools to deliver credible, audit-ready evidence and continuous compliance.

Reference Architecture for Posture Program

From Standards → Evaluation → Prevention → Risk Context → Operational Governance



Conclusions

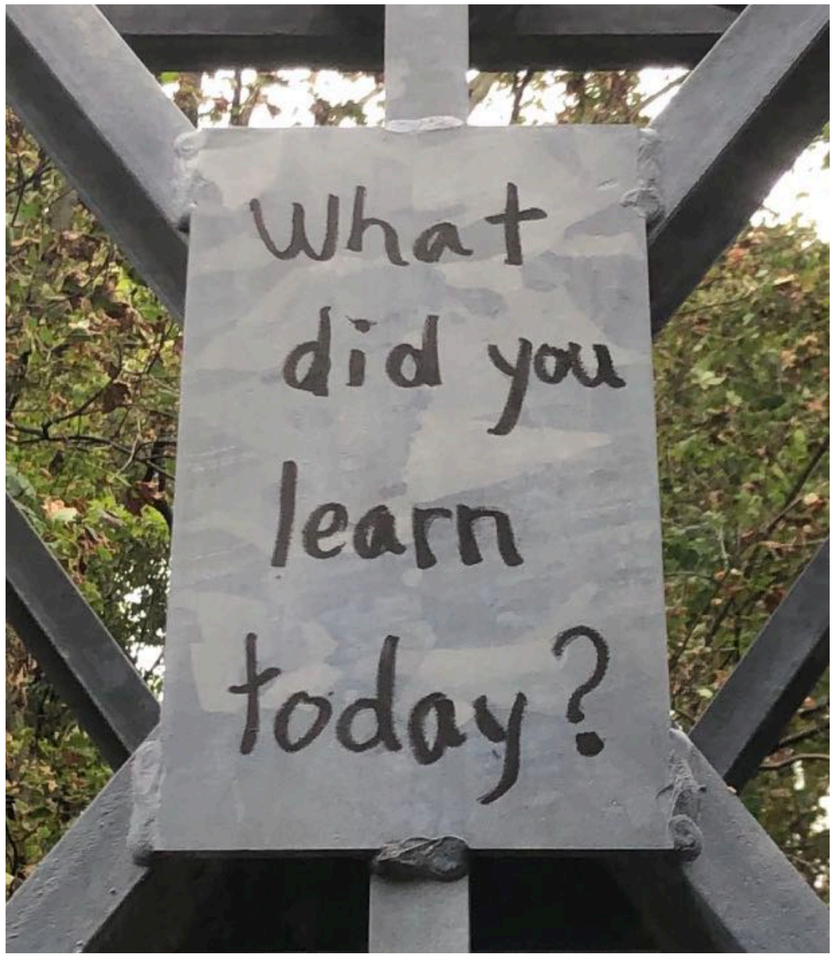
- Security Posture Management:
  - Is not a product, dashboard, or score
  - Is not something you can win
  - Is an operational process

- Things that matter:
  - Posture domains
  - Requirements
  - Accountability

- Successful programs:
  - Effectively identify drift
  - Prioritise risk
  - Remediate problems
  - Repeat consistently

- Security programs fail when they become reporting programs.

- “Free” is the lie we tell ourselves



Questions?



Thank you

Contact Info:

singleusermode@infosec.exchange
nixuser23@gmail.com

Do not contact me on LinkedIn unless you talk to me first or personalise your request



This QR code is safe… honest…

https://github.com/nixy23/hf2026

Resources & Links

CIS Benchmarks - Configuration standard baselines for M365 and Azure
https://www.cisecurity.org/benchmark/microsoft_365
https://www.cisecurity.org/benchmark/azure

ScubaGear - Assessment of Microsoft 365 configurations against CISA Secure Cloud Business Applications (SCuBA) guidance.
PowerShell queries M365 APIs, Open Policy Agent compares results against Rego policies, and reports are generated in HTML, JSON, and CSV
https://www.cisa.gov/resources-tools/services/secure-cloud-business-applications-scuba-project
https://github.com/cisagov/ScubaGear
https://github.com/cisagov/ScubaConnect

Microsoft365DSC - Configuration auditing, drift detection, and desired-state validation for Microsoft 365
Uses PowerShell and MS Graph due to insufficient Graph coverage for some services.
https://github.com/Microsoft365DSC/Microsoft365DSC
https://microsoft365dsc.com/user-guide/get-started/introduction/

Prowler - Open-source cloud security assessments with support for Azure and Microsoft 365 security checks. Powershell and Graph based collection
Better posture depth than native MS Secure Score
https://docs.prowler.com/getting-started/products/prowler-cli
https://docs.prowler.com/getting-started/products/prowler-app

Steampipe - SQL-based cloud security and compliance queries with dashboards for Azure and Microsoft 365.
https://hub.steampipe.io/

Checkov - Infrastructure as Code (IaC) scanning Terraform, ARM templates, Kubernetes manifests before Azure deployment provided by Prisma Cloud
https://www.checkov.io/
https://github.com/bridgecrewio/checkov

Cloud Custodian - Compliance as Code (CaC) using YAML-based rules engine and event drive execution of policy definition and enforcement across public cloud accounts, including Azure
https://cloudcustodian.io/
https://github.com/cloud-custodian/cloud-custodian

Resources & Links

Open Policy Agent - Policy as Code (PaC) using Rego and JSON inputs to enforce rules across CI/CD, Kubernetes, APIs, etc.
https://www.openpolicyagent.org/docs
https://github.com/open-policy-agent/opa

Purple Knight - Identity governance over Entra and on premises Active Directory provided by Sempris
https://www.semperis.com/purple-knight/

Forest Druid - AD and Entra attack path mapping for identities provided by Sempris
https://www.semperis.com/forest-druid/

Azure Policy - Native Azure governance and compliance monitoring.
https://learn.microsoft.com/en-us/azure/governance/policy/overview

ScoutSuite - multi-cloud security-auditing tool, which enables security posture assessment of cloud environments
https://github.com/nccgroup/ScoutSuite

Monkey365 - Conduct Microsoft 365, Azure, and Microsoft Entra ID security configuration reviews with output to HTML, JSON, or CSV
https://silverhack.github.io/monkey365/

AADInternals - PowerShell modules containing tools for administering and offensively testing Entra ID (ex. Azure AD), Office 365, and Entra ID related endpoints.
https://aadinternals.com/aadinternals/

365Inspect - PowerShell script that automates the security assessment of Microsoft 365 environments provided by Soteria
https://github.com/soteria-security/365Inspect

M365SAT - “The Official Microsoft 365 Security Assessment Tool”
https://github.com/CompliantSec/M365SAT

M365assessment
https://github.com/System-Admins/m365assessment

Resources & Links

SkyArk - Focus on mitigating Cloud Shadow Admins, and helps organisations to discover, assess, and protect cloud privileged entities provided by CyberArk
https://github.com/cyberark/SkyArk

M365 Unified Tenant Configuration Management API query tools - PowerShell script to create tenant config snapshots, allow for comparison and identify configuration drift
https://github.com/therealtadda/M365UTCMPowershell

Microsoft Graph PowerShell SDK - Custom security auditing and reporting.
https://learn.microsoft.com/en-us/powershell/microsoftgraph/overview?view=graph-powershell-1.0

Azure Resource Graph - Large-scale resource inventory and posture analysis.
https://azure.microsoft.com/en-us/get-started/azure-portal/resource-graph/

Azure-Audit - comprehensive, modular platform designed to audit Azure cloud environments for security compliance, operational best practices, and regulatory adherence- tons of dependancies - AzureCLI, Python, NPM, Node.js and many others. Out of date, numerous broken issues.
https://github.com/adrian207/Audit-Azure

Azure Security Scanner - subscription audit with 70+ checks across 16 sections, CIS Azure Foundations Benchmark v4.0.0 alignment, and evidence collection
https://phalanxcyber.ai/tools/azure-scanner.html
https://github.com/Krishcalin/Azure-Security-Scanner

Azure CIS Scanner - out of date / not maintained - python 3.14 only
https://github.com/kbroughton/azure_cis_scanner

EntraGoat - Deliberately vulnerable Entra ID
https://github.com/Semperis/EntraGoat

Microsoft Entra ID - Attack and Defence Playbook - common attack scenarios on Microsoft Entra and how they can be mitigated or detected.
https://github.com/Cloud-Architekt/AzureAD-Attack-Defense

ASD Automated Deployment and Configuration Assessment tools - designed for M365DSC
https://blueprint.asd.gov.au/tools/deployment-and-assessment/automated-deployment/
https://blueprint.asd.gov.au/tools/deployment-and-assessment/configuration-assessment/

Resources & Links

Automating Assessment and Enforcement in the Cloud - Rich Mogull

Microsoft cloud security benchmark documentation
https://learn.microsoft.com/en-us/security/benchmark/azure/

Output Format Comparison by Assessment Maturity

Output Requirement	Recommended Tools
Executive Reports (HTML/PDF)	Purple Knight, ScoutSuite, Monkey365, Prowler, Azure Security Scanner
CSV for Spreadsheet Analysis	ScubaGear, Monkey365, Prowler, Azure Security Scanner, M365SAT
JSON for Automation Pipelines	ScubaGear, Prowler, Checkov, OPA, Azure Policy, Azure Resource Graph
Configuration Baselines / Drift Files	Microsoft365DSC, UTCM Tools, Azure Policy
Interactive Dashboards	Steampipe, Azure Policy, Prowler App, Forest Druid
Power BI Friendly Data Sources	Monkey365, Azure Resource Graph, Graph PowerShell SDK
CI/CD Security Results	Checkov, OPA, Cloud Custodian, Microsoft365DSC
Attack Path Visualisation	Forest Druid, SkyArk
Identity Security Assessments	Purple Knight, Forest Druid, SkyArk, AADInternals

Best Overall Coverage by Security Gap and Deliverable

Security Gap	Tool	Typical Output
Security Baselines	CIS Benchmarks	Benchmark documentation
M365 Compliance	ScubaGear	HTML, CSV, JSON
Azure Compliance	Azure Policy, Prowler	Dashboards, JSON, HTML
Configuration Drift	Microsoft365DSC, UTCM Tools	DSC, JSON, PowerShell
CSPM Assessment	Prowler, Monkey365, ScoutSuite	HTML, CSV, JSON
Identity Governance	Purple Knight	HTML, PDF
Attack Path Analysis	Forest Druid	Graph visualization
Shadow Admin Discovery	SkyArk	HTML, CSV
IaC Security	Checkov	SARIF, JSON, JUnit XML
Compliance-as-Code	OPA, Cloud Custodian	JSON, policy evaluation results
Azure Resource Inventory	Azure Resource Graph	KQL, JSON, CSV
Custom Auditing	Graph PowerShell SDK	Custom reports, JSON, CSV

Usage Scenarios

Objective	Tool options
CIS Benchmark Compliance	CIS Benchmarks + Prowler + Azure Security Scanner + Microsoft365DSC
Microsoft 365 Security Assessment	ScubaGear, Monkey365, Microsoft365DSC, 365Inspect
Azure Governance & Compliance	Azure Policy, Prowler, Steampipe, Cloud Custodian
Configuration Drift Detection	Microsoft365DSC, UTCM Tools, Azure Policy
Identity Security Review	Purple Knight, Forest Druid, SkyArk, AADInternals
Infrastructure-as-Code Validation	Checkov, OPA, Cloud Custodian
Custom Security Reporting	Graph PowerShell SDK, Azure Resource Graph, Steampipe
Open Source Enterprise Assessment	Monkey365, Prowler, Microsoft365DSC, ScoutSuite, ScubaGear